

Seeking Risk Acceptance Approval VMS

ID	Risk Statement	Current Risk			Change Since Last Assessment	Mitigation Action to Address the Identified Risk	Status of Mitigation Action	Residual Risk Level after Mitigation in Place			Expiry Date* (DD-MM-YY)
		Likelihood	Impact	Risk				RL	RI	RR	
01	298656 - Vim < 9.1.2132 Buffer Overflow (GHSA-5w93-4g67-mm43) CVE-2026-25749 The version of Vim installed on the remote host is prior to 9.1.2132 and is vulnerable to the issue described in the GHSA-5w93-4g67-mm43 advisory. Vim, an open-source text editor, has a heap buffer overflow vulnerability in versions before 9.1.2132. The issue occurs in the get_tagfname() function in src/tag.c when processing the 'helpfile' option. The vulnerability allows unsafe copying of the 'helpfile' value into a fixed-size heap buffer using the STRCPY() function without bounds checking Affected Devices:- 24 RHEL Servers Reason for Risk Acceptance: We request Risk Acceptance (RA) for vulnerability CVE-2026-25749 on our RHEL servers. This issue related to a heap buffer overflow in Vim, currently affects RHEL 8. Red Hat has not released a security patch or errata for this CVE. Since no vendor fix is available at this time, we seek approval to accept the risk until 31 Aug 2026.	Likely (4)	Minor (2)	Medium (8)	No change	1) The server is hosted in the internal network which is only accessible by CAM and can only be accessed by authorized user. 2) The web application is not used by any other users except Very Renowned SI. 3) Firewall and IPS solution are implemented within the Renowned infra with network monitoring in place to aid in the detection of any potential malicious or unauthorized activities.	Implemented	Unlikely (2)	Minor (2)	Low (4)	31-08-2026

Risk Assessment

Current Risk (Before Mitigation is in Place): **Medium**

Impact on	Rating	Reason for the rating	Likelihood on	Rating	Reason for the rating
Confidentiality & Integrity	2	The unauthorised disclosure or modification of information classified as Restricted for an individual or business.	Discoverability	4	Can be discovered by probing the target (e.g. port scans).
			Exploitability	4	Can be performed with publicly available tools with basic technical knowledge.
Availability	2	The unavailability of a system may result in a minor impact to the Nation, an agency, an individual, or business.	Reproducibility	3	Can be repeated given certain predictable event condition.
Overall Rating	2	Minor	Overall Rating	4	$(4+4+3)/3 = 3.67 = 4$

Residual Risk (After Mitigation is in Place): **Low**

Impact on	Rating	What mitigation is in place to bring down rating	Likelihood on	Rating	What mitigation is in place to bring down rating
Confidentiality & Integrity	2	The unauthorised disclosure or modification of information classified as Restricted for an individual or business.	Discoverability	2	Can be discovered by operating and interacting with the actual or similar setup of the target.
			Exploitability	2	May requires chaining of multiple exploits, as there are IPS and firewall to deter the exploitation.
Availability	2	The unavailability of a system may result in a minor impact to the Nation, an agency, an individual, or business.	Reproducibility	1	Cannot be reproduced on the target as firewall rules and IPS monitoring are in place to detect malicious activities.
Overall Rating	2	Minor	Overall Rating	2	$(2+2+1)/3 = 1.67 = 2$

Things to Note

- When deciding the impact & likelihood, please base it on the vulnerability against the affected system.
- If the risk item has more than 1 CVE, you will need to assess all CVEs and use the details of the CVE of the higher residual risk.
- Impact Rating
 - Select the impact of higher precedence. Example:
 - If the impact on Confidentiality & Integrity is **Moderate** and
 - If the impact on availability is **Severe**
 - Then the overall impact is **Severe**
- Likelihood Rating
 - The overall likelihood is the average of the sum of Discoverability, Exploitability and Reproducibility, rounded to the nearest place¹. Example:
 - If Discoverability is **Likely (4)**, and
 - If Exploitability is **Highly Likely (5)**, and
 - If Reproducibility is **Unlikely (2)**
 - Then the overall likelihood is $(4 + 5 + 2) \div 3 = 3.66 \approx 4$

¹Rounded to the nearest place:

If value is x.33: Round down (Eg: 1.33 $\approx$ 1)

If value $\geq$ x.5: Round up (Eg: 1.5 $\approx$ 2 or 1.66 $\approx$ 2)

Impact Ratings

Impact Level	Impact on Confidentiality and Integrity	Impact on Availability
Very Severe (5)	The unauthorised disclosure or modification of information classified: • TOP SECRET; or • SENSITIVE-HIGH for multiple individuals or businesses	The unavailability of a system may result: • A very severe impact to the Nation, an agency, an individual, or business; or • A severe impact to multiple agencies, individuals, or businesses
Severe (4)	The unauthorised disclosure or modification of information classified: • SECRET; or • SENSITIVE-HIGH for an individual or business	The unavailability of a system may result: • A severe impact to the Nation, an agency, an individual, or business; or • A moderate impact to multiple agencies, individuals, or businesses
Moderate (3)	The unauthorised disclosure or modification of information classified: • CONFIDENTIAL; or • SENSITIVE-NORMAL for multiple individuals or businesses	The unavailability of a system may result: • A moderate impact to the Nation, an agency, an individual, or business; or • A minor impact to multiple agencies, individuals, or businesses
Minor (2)	The unauthorised disclosure or modification of information classified: • RESTRICTED; or • SENSITIVE-NORMAL for an individual or business	The unavailability of a system may result in a minor impact to the Nation, an agency, an individual, or business
Negligible (1)	The unauthorised disclosure or modification of information classified: • OFFICIAL-CLOSED, or OFFICAL-OPEN; or	The unavailability of a system may result in a negligible impact to the Nation, an agency, individual, or business

Likelihood Ratings (CyberSecurity) – Discoverability (1/3)

Likelihood	Discoverability
Highly Likely (5)	For cybersecurity, the vulnerability of the target: • Can be discovered by searching / scanning the public domain for published information (e.g. Shodan, ExploitDB); • Can be discovered and attacked from external networks (including the internet).
Likely (4)	For cybersecurity, the vulnerability of the target: • Can be discovered by probing the target (e.g. port scans); • Can be discovered and attacked from adjacent subnets or network segments.
Possible (3)	For cybersecurity, the vulnerability of the target: • Can be discovered by examining the target's responses, behaviour and communications (e.g. fuzzing with network packets, network sniffing); • Can be discovered and attacked from within the same subnet or network segment.
Unlikely (2)	For cybersecurity, the vulnerability of the target: • Can be discovered by operating and interacting with the actual or similar setup of the target; • Can be discovered and attacked with logical local access.
Rare (1)	For cybersecurity, the vulnerability of the target: • Can be discovered by studying the blueprint (e.g. source code); • Can be discovered and attacked with physical access.

Likelihood Ratings (CyberSecurity) – Exploitability (2/3)

Likelihood	Exploitability
Highly Likely (5)	For cybersecurity, the attack: • Can be performed with no access rights of the target; • Can be performed with publicly available tools without technical knowledge.
Likely (4)	For cybersecurity, the attack: • Can be performed with restricted access rights of the target (e.g. user); • Can be performed with publicly available tools with basic technical knowledge.
Possible (3)	For cybersecurity, the attack: • Can be performed with privilege access rights of the target (e.g. admin/SYSTEM/root); • Can be performed with publicly available tools that requires moderate technical knowledge.
Unlikely (2)	For cybersecurity, the attack: • Can be performed with privilege access rights (e.g. admin/SYSTEM/root); • Can be performed with publicly available/specialise tools that requires advance technical knowledge; • May requires chaining of multiple exploits.
Rare (1)	For cybersecurity, the attack: • Can be performed with privileged access rights (e.g. admin/root/SYSTEM) and required multi-factor authentication; • Can be performed with specialised tools that requires expert technical knowledge; • Requires chaining of multiple exploits.

Likelihood Ratings (CyberSecurity) – Reproducibility (3/3)

Likelihood	Reproducibility
Highly Likely (5)	For cybersecurity, the attack: • Can be repeated at will without any specific *configuration or **event condition; • Can be repeated at will without any customisation of the published exploits.
Likely (4)	For cybersecurity, the attack: • Can be repeated given certain configuration in the target; • Can be repeated with minimal customisation of the published exploits (e.g. change of parameters).
Possible (3)	For cybersecurity, the attack: • Can be repeated given certain predictable event condition; • Can be repeated with customisation specific for the target.
Unlikely (2)	For cybersecurity, the attack: • Can be repeated given certain random event condition; • Can be repeated theoretically or with published proof of concept exploit.
Rare (1)	The attack: • Cannot be reproduced on the target; • Can be repeated with unpublished exploit specific for the target.

Risk Matrix

- The risk level for each risk scenario is determined from the combined effect of impact and likelihood

Likelihood of Risk Occurring		Rare (1)	Unlikely (2)	Possible (3)	Likely (4)	Highly Likely (5)
Impact of Risk Occurring	Very Severe (5)	Medium (5)	Medium-High (10)	High (15)	Very High (20)	Very High (25)
	Severe (4)	Low (4)	Medium (8)	Medium-High (12)	High (16)	Very High (20)
	Moderate (3)	Low (3)	Medium (6)	Medium (9)	Medium-High (12)	High (15)
	Minor (2)	Low (2)	Low (4)	Medium (6)	Medium (8)	Medium-High (10)
	Negligible (1)	Low (1)	Low (2)	Low (3)	Low (4)	Medium (5)